

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Analytics vendor controller
Management units responsible	Product Engineering; Legal / Compliance; Data Protection
Main establishment / point of contact	EU main establishment / point of contact
DPO or similar function	DPO or privacy contact

Processor(s) and Sub-processor(s)

#	Processor	Obligations and Tasks
1	co-mission LLC (Shyware SDK licensor)	Provides SDK and related hosted processor services under the customer's documented instructions; processes customer user data under the Shyware DPA
2	EU-region cloud infrastructure provider	Hosts canonical ledger nodes and off-chain reconciling store; processes personal data under controller's instructions per Article 28 DPA
3	Identity verification provider	Biometric identity verification for user-authenticated reconciling requests only; no access to behavioral payload or canonical ledger state

Name of the Processing

Internal name: Shyware-SDK-Integrated Behavioral Analytics

Record of processing activities reference:

Planning of the Processing

Field	Value
Estimated launch date	
Estimated end date	Ongoing — subject to annual DPIA review or material architecture change

DPIA Technical Sheet

Field	Value
Current version	1.0
Team involved	DPO; Product Engineering Lead; Privacy Counsel; External privacy counsel
Reference materials	EDPB DPIA Template v1.0 (March 2026); Austrian DSB Decision D155.027 (Jan 2022) — Google Analytics; German Standard Data Protection Model (SDM) v3.1 — unlinkability protection goal; EDPB Guidelines 02/2024 on Article 48 GDPR; BfDI Technical Guidance on Unlinkability (June 2025); LinkedIn behavioral analytics fine — IE DPA (Oct 2024, €310M)
Reason to conduct DPIA	New processing activity — high risk under Article 35(3)(a) GDPR (systematic and extensive evaluation of personal aspects via automated processing, at scale); innovative architectural approach (Art. 35(1)); EDPB and national DPA guidance targets behavioral analytics (SDM unlinkability benchmark)
Scope	Full DPIA covering behavioral analytics processing under Shyware SDK integration by the controller. Legacy analytics architecture is outside this assessment.
Completion date	
Formal validation date	
Publication	Internal DPIA record. External sharing is limited to parties with a documented need to know.

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data	
		Subject Category	Special Category
1	Session identifier (List 1 record)	Direction-free opaque identifier; no behavioral direction, no identity attribute	No
2	Behavioral payload commitment (List 1 record)	AES-256-GCM sealed byte sequence; content inaccessible without controller-held sealer key	No
3	Identity hash (List 2 record)	SHA-256 of verified identity credential; no behavioral payload; no session identifier	No
4	Aggregate count per scoping period	Integer count of List 1 and List 2 entries per scoping period; no individual linkage	No
5	Period-close attestation	HSM-signed Merkle roots over disjoint List 1 and List 2 sets at period close; no individual record linkage	No
6	User-authenticated reconciling record	Per-user behavioral history in off-chain reconciling store; accessible only via identity-gated, non-composable reconciling authority interface	No

Canonical state architecture: Items 1–5 are canonical ledger records. The canonical state

contains no record associating any List 1 entry (behavioral payload) with any List 2 entry (identity hash). This is a structural property of the Shyware state machine: the rejection predicate refuses any state transition that would create such an association. Items 1 and 3 share no join key in canonical state by architectural enforcement, not by policy.

List 2 Sealed-Attribute Content (shyIDV) When `anon_layer.shyIDV: true` (as configured in `shybrowser-v1`), the List 2 record is not a plain identity hash but an **AES-256-GCM sealed envelope**. The sealed envelope may contain the following browser session attributes as configured by the operator. This is the primary instantiation of the Mainhub patent’s formulation: *“the second canonical record . . . may additionally include any participant attribute — such as real IP address, device attestation verdict, geolocation, or other network or forensic attribute — that enables operator or authority reconcilability, compliance, abuse prevention, or forensic analysis, while preserving structural anonymity”* (composition.tex). The structural anonymity guarantee holds regardless of what attributes appear in List 2: the rejection predicate prevents any join key between List 1 and List 2 by write architecture, not by policy.

Attribute	Data type	Legal basis (Art. 6 GDPR)
IP address	Pseudonymous network identifier	Art. 6(1)(f) legitimate interest (fraud/sybil prevention); or Art. 6(1)(a) consent where tracking-adjacent
User agent string	Browser and device fingerprint component	Art. 6(1)(f) legitimate interest (device compatibility, sybil detection)
Session token (hashed)	Ephemeral per-session opaque identifier	Art. 6(1)(b) service performance; rotated per session
Device fingerprint hash	Aggregated browser characteristics	Art. 6(1)(f) legitimate interest; Art. 6(1)(a) consent if used for cross-session tracking
Identity commitment	SHA-256 of verified identity credential	Art. 6(1)(f) sybil resistance and count-match integrity

Operator action required: The operator must (a) enumerate in their privacy notice which of the above attributes are included in List 2 for their specific deployment, (b) identify the legal basis for each attribute, and (c) confirm that the sealer key is held exclusively by the reconciling authority (not the IDV provider or auth provider). If IP address or device fingerprint is included, assess whether the processing constitutes tracking under ePrivacy Directive Art. 5(3) and obtain consent where required.

Structural guarantee preserved: The AES-256-GCM sealed List 2 envelope is written atomically with the List 1 behavioral payload commitment. The sealing key is not in canonical

state. No canonical-state query yields the association between List 1 content and List 2 attributes. The guarantee extends to all attribute combinations above — the sealed envelope’s richer content does not weaken the structural non-linkability property.

Purposes of the Processing

#	Purpose	Personal Data	Legal Basis
		Involved	
1	Behavioral analytics — aggregate session tracking	Items 1, 2, 4, 5	Article 6(1)(f) — legitimate interests; identity not linkable to behavior in canonical state
2	Identity verification — sybil resistance	Item 3	Article 6(1)(f) / (b) — service integrity; one canonical record per verified user per scoping period
3	Period-close attestation — compliance audit	Item 5	Article 6(1)(f) / (c) — regulatory audit; aggregate only; no individual linkage
4	User-authenticated behavioral history retrieval	Item 6	Article 6(1)(b) — contract performance; user-initiated only; operator cannot initiate

Secondary or Compatible Uses

#	Secondary Use	Personal Data	Compatibility
		Involved	Assessment
1	Regulatory audit — DPA inspection	Items 4, 5 only	Compatible: aggregate counts and HSM attestations only; no identity-behavior association in canonical state

#	Secondary Use	Personal Data Involved	Compatibility Assessment
2	User-initiated disclosure to third party (delegation)	Item 6	Compatible: user authenticates and explicitly authorizes via reconciling authority interface; operator cannot initiate or compel

Nature, Scope and Context of the Processing **Nature:** Behavioral analytics using a two-list state machine (Shyware SDK). Behavioral events are atomically committed to a distributed ledger as two structurally disjoint records: List 1 (sealed behavioral payload, no identity) and List 2 (identity hash, no behavioral payload). No join key is written to canonical state. Operator-level enumeration — querying “all users who performed behavior X” — is structurally unavailable because canonical state does not contain sufficient information to derive the association.

Scope: EU enterprise users of the analytics vendor’s platform across DACH, Benelux, and France. Processing operates at scale within the meaning of Article 35(3)(b) GDPR. Frequency: per-session event writes; continuous during active user sessions.

Context: B2B analytics SDK deployed by an analytics vendor to enterprise customers with EU legal entities. Enterprise customers operate simultaneously under Austrian, German, Belgian, and French DPA jurisdiction. The controller cannot rely on CNIL’s conditional endorsement of server-side tagging because enterprise customers face stricter enforcement in DACH and Benelux (Austrian DSB 2022; German SDM unlinkability benchmark; Belgian DPA TCF rejection 2024).

Cross-border processing: Yes — processing occurs across EU member states including DE, AT, BE, NL, and FR.

Third country transfer: No third-country transfer for canonical ledger state or off-chain reconciling store (EU-region hosting). IDV provider (the identity verification provider) — subject to separate Chapter V assessment; SCCs applied where IDV provider operates outside EEA.

Functional Description

Phase	Operations	Explanation
Collection	User behavioral event captured client-side via SDK	SDK generates direction-free session identifier and AES-256-GCM sealed behavioral payload; no raw behavioral data transmitted without sealing
Use	Two-list atomic write to distributed ledger	List 1 (session ID + sealed payload) and List 2 (identity hash) committed atomically; rejection predicate enforced at validation layer before consensus commit
Storage	Canonical ledger state + off-chain reconciling store	Canonical ledger: disjoint List 1 and List 2 records only (no join key). Off-chain (CockroachDB EU-region): per-user behavioral history, identity-gated
Sharing and Transfer	User-authenticated reconciling retrieval only	No operator-initiated sharing. User authenticates via IDV; reconciling authority returns that user's history only. Non-composable: no cross-user queries
Deletion and Destruction	Credential-free rescission — atomic L1+L2 deletion	User authenticates via biometric IDV; reconciling authority co-signs deletion of both List 1 and List 2 records; count-match invariant preserved post-deletion

Means of Processing, Supporting Assets and Underlying Architecture

Asset Group	Asset	Role in Processing
Validation layer	Shyware state machine (Go binary; distributed ledger node)	Enforces rejection predicate before consensus commit; refuses state transitions creating identity-payload association
Sealing	AES-256-GCM; sealer key (controller-held, HSM-backed)	Seals behavioral payload before write; sealer key never written to canonical state
Identity binding	SHA-256(identity credential); IDV provider	Derives identity hash for List 2; raw credential not written to canonical state
Signing / attestation	AWS KMS (ECC_NIST_P256, FIPS 140-3 L3) or AWS CloudHSM	Signs disjoint Merkle roots at period close; public key enables third-party verification
Off-chain store	CockroachDB (EU-region, encryption at rest)	Stores per-user behavioral history; identity-gated, non-composable API only
Identity / recovery	Identity verification provider	Biometric re-derivation for user-authenticated retrieval and credential-free rescission
SDK distribution	Signed SDK releases; reproducible builds	Integrity of rejection predicate enforced via supply chain controls

Compliance with Approved Codes of Conduct

Code of Conduct	Assessment
IAB Europe TCF v2.2	Not relied upon. Belgian DPA (2024) and Dutch DPA (2025) found IAB TCF structurally incompatible with GDPR for behavioral tracking. Controller relies on Article 6(1)(f) legitimate interests and architectural minimization.
Cloud infrastructure provider code of conduct	Not applicable

ANALYSIS OF THE PROCESSING

Lawfulness of the Processing

Legal Basis

Purpose	Legal Basis (Article 6(1) GDPR)	Justification
Aggregate behavioral analytics	(f) Legitimate interests	Legitimate interest: product improvement, service quality. Balancing test: data subject impact is structurally minimized — identity is not linkable to behavior in canonical state; operator-level enumeration is architecturally unavailable. Outweighs data subject privacy interest.
Identity verification / sybil resistance	(f) Legitimate interests / (b) Contract performance	Necessary for service integrity. Identity hash reveals no behavioral content.
Period-close attestation	(f) Legitimate interests / (c) Legal obligation	Regulatory audit readiness; aggregate data only; no individual linkage.
User-authenticated history retrieval	(b) Contract performance	User requests own data as part of service. User-initiated only; operator cannot initiate.

Consent basis excluded: Controller does not rely on Article 6(1)(a) consent for behavioral analytics. Consent is systematically rejected by EU DPAs as a valid basis for behavioral profiling when effectively a condition of service access. See: LinkedIn behavioral advertising fine — IE DPA (Oct 2024, €310M); Meta behavioral advertising fine (2023, €390M). Structural minimization under legitimate interests is the legally preferred basis.

Reasons to Lift Processing Prohibition Not applicable. No special category personal data (Article 9 GDPR) is processed. Identity hashes are pseudonymous identifiers. Biometric data is processed exclusively by the IDV provider under a separate legal basis and is not transmitted to or stored by the controller.

Data Minimisation, Retention Periods, and Data Quality

Data Minimisation and Retention Periods

Personal Data				
Item	Justification	Recipients	Retention Period	Justification
Session identifier (List 1)	Minimum necessary for behavioral analytics	Controller; canonical ledger nodes	24 months from last user activity, or until user-initiated rescission	Aligned with analytics service lifecycle; structural minimum
Sealed behavioral payload (List 1)	Minimum necessary for product analytics	Controller only (sealer key required)	24 months or until rescission	Sealed at rest; inaccessible without sealer key
Identity hash (List 2)	Minimum necessary for sybil resistance	Controller; canonical ledger nodes	24 months or until rescission	No behavioral content; cannot identify user without IDV
Aggregate count / period-close attestation	Minimum necessary for regulatory audit	Controller; regulatory authority on inspection	7 years (regulatory audit obligation)	Aggregate only; no individual linkage
Off-chain reconciling record	Minimum necessary for user-authenticated retrieval	User only (identity-gated); IDV for authentication only	Until user-initiated rescission	Per-user; non-composable; deleted on user request

Data Quality

Personal Data Item	Quality Metrics	Justification
Identity hash	Deterministic derivation from IDV-verified credential; refreshed on re-attestation	Accuracy maintained by IDV re-verification; stale hashes invalidated on re-attestation
Session identifier	Opaque; direction-free; not individually correctable by design	Structural property; no accuracy obligation attaches to a direction-free identifier
Period-close attestation	HSM-signed; append-only; immutable	Integrity guaranteed by HSM signing key; count-match verifiable by any third party with public key

Measures Supporting Compliance with Article 5(1) GDPR Principles

Principle	Supporting Measures	Appropriateness and Effectiveness	Status
Fairness	Structural non-representability: operator cannot derive identity-behavior association from canonical state by any query	Architectural guarantee — not policy-dependent; survives operator compromise	Implemented
Transparency	User-facing privacy notice describing two-list architecture, sealing, and user-authenticated retrieval path	Standard; architecture is describable without revealing security internals	Implemented
Purpose limitation	Rejection predicate structurally prevents canonical state from being used for purposes requiring identity-behavior join; no secondary use of join because join does not exist	Structural enforcement at validation layer; not configurable by operator	Implemented
Data minimisation	List 1: no identity. List 2: no behavioral payload. No join key committed. Aggregate-only period-close attestation. German SDM unlinkability protection goal satisfied.	Structural minimum — less cannot be stored while preserving service functionality	Implemented

Principle	Supporting Measures	Appropriateness and Effectiveness	Status
Accuracy	IDV re-attestation for identity hash; AES-256-GCM for payload integrity	Cryptographic integrity; re-attestation enforces accuracy	Implemented
Storage limitation	24-month retention per data item; user-initiated rescission supported (atomic L1+L2 deletion)	Retention periods defined and technically enforced	Planned (pre-launch)
Integrity and confidentiality	AES-256-GCM payload sealing; TLS 1.3 in transit; HSM-backed signing; no operator access to sealed content without sealer key; BFT consensus	Defense-in-depth; multiple independent controls	Implemented
Accountability	DPIA documented; annual review; DPO consulted; ROPA maintained	Standard	Implemented

Measures Supporting Exercise of Data Subject Rights

Right	Supporting Measures	Effectiveness	Status
Information (Articles 12–14)	Privacy notice describing architecture, legal basis, retention periods, and user-authenticated retrieval path	Standard; architecture fully describable	Implemented

Right	Supporting Measures	Effectiveness	Status
Access and portability (Articles 15, 20)	User-authenticated reconciling authority interface returns full behavioral history in machine-readable format; no operator intermediation required	Structural: user accesses own data without operator involvement	Implemented
Rectification and erasure (Articles 16, 17)	Credential-free rescission: atomic L1+L2 deletion co-signed by reconciling authority; count-match invariant preserved; biometric re-derivation removes memorized-secret dependency	Structural: no secret required; biometric re-derivation enables erasure on any device	Implemented
Object and restrict (Articles 18, 19, 21)	User may object to legitimate-interest processing; controller assesses compelling grounds; rescission available if objection upheld	Standard objection handling	Planned
No solely automated decision-making (Article 22)	No automated decisions with legal or similarly significant effect are made on the basis of behavioral analytics output	N/A	N/A

Measures Supporting Compliance with Other GDPR Requirements

Requirement	Supporting Measures	Effectiveness	Status
Consent requirements (Article 7)	Consent not relied upon as legal basis; no consent management infrastructure required	N/A — basis is legitimate interests	N/A
Processor relationship (Article 28)	Shyware DPA executed with the customer under Article 28. Shyware acts as processor for customer user data processed through the SDK and related hosted services.	DPA in place	Implemented
International transfers (Chapter V)	Canonical ledger and off-chain reconciling store: EU-region hosting, no transfer. IDV provider: SCCs applied where provider operates outside EEA; separate Chapter V assessment documented.	EU data residency for primary processing; SCC coverage for IDV	Implemented / In progress

Measures Supporting Data Protection by Design and by Default (Article 25 GDPR)
State-space exclusion — primary architectural measure:

The Shyware SDK enforces data protection by design through the rejection predicate: the state machine refuses any state transition that would write a record containing sufficient information to derive an association between a List 1 entry (behavioral payload) and a List 2 entry (identity hash). This is not a policy, a configuration option, or an access control — it is a property of the reachable canonical state space. No operator-level query can reconstruct the identity-behavior join because canonical state never contained the join.

This supports Article 25 GDPR at the canonical state-machine layer. The Austrian DSB’s 2022 Google Analytics decision found that pseudonymization retaining a join capability — even if not routinely exercised — constitutes personal data processing because the operator *could* derive the association. The Shyware architecture eliminates that specific canonical-state representability risk: reachable canonical state does not contain sufficient information for the join regardless of

operator capability or intent. Other operational risk surfaces remain separately assessed in this DPIA.

References: Austrian DSB Decision D155.027 (January 2022); German SDM v3.1, Protection Goal: Unlinkability; BfDI Technical Guidance on Unlinkability (June 2025).

Default minimization: Aggregate-only analytics by default. User-authenticated reconciling access available on request. Operator-level behavioral history unavailable by design.

Measure	Appropriateness	Status
State-space exclusion (rejection predicate)	Architectural; satisfies Article 25 at design layer independently of organizational controls	Implemented
AES-256-GCM payload sealing	Content inaccessible without sealer key; sealer key excluded from canonical state	Implemented
Non-composable reconciling interface	Per-user only; no cross-user queries; no reverse lookup; non-enumerable	Implemented
Default aggregate-only posture	No opt-in required; maximum privacy enforced by default	Implemented

Measures Supporting Security of Processing (Article 32 GDPR)

Measure	Appropriateness	Status
AES-256-GCM payload sealing	Industry standard; FIPS 140-2 compliant	Implemented
TLS 1.3 in transit	Standard transport security	Implemented
HSM-backed period-close signing (AWS KMS ECC_NIST_P256, FIPS 140-3 L3)	Hardware-enforced; no key material exposure	Implemented
BFT distributed ledger consensus	Byzantine fault tolerant; no single point of failure for canonical state	Implemented
CockroachDB EU-region, encryption at rest	Standard cloud database security	Implemented
Identity-gated reconciling API (IDV re-auth per request)	No anonymous access; no session persistence	Implemented

Measure	Appropriateness	Status
Signed SDK releases, reproducible builds	Supply chain integrity of rejection predicate	Planned (pre-launch)

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

Impacts on Rights and Freedoms

Threat	How it can materialise	Risk Source	Impact on Rights
Re-identification via operator enumeration	Operator queries canonical state to link identity to behavior	Architectural gap allowing join	Not applicable — canonical state structurally excludes join key; rejection predicate prevents this reachable state
Sealed payload decryption	Sealer key compromised	Key management failure	Behavioral content exposed; identity still not linkable without canonical join key
Off-chain reconciling store breach	Database compromise	Infrastructure vulnerability	Per-user behavioral history exposed for affected users; mitigated by identity-gating and encryption at rest
IDV provider compromise	IDV credential theft or breach	Third-party risk	Identity re-derivation risk; behavioral history not exposed without separate reconciling store breach
Coercion / compelled delegation	User forced to share reconciling history	Social or contractual pressure	User-initiated delegation is voluntary and authenticated; operator cannot compel via API

Necessity Assessment

The Shyware architecture implements the minimum necessary processing for behavioral analytics at enterprise scale: no operator-level identity-behavior join is created at any layer. This is the least intrusive design available that satisfies the German SDM unlinkability protection goal and the Austrian DSB’s re-identification standard.

Alternative architectures assessed and rejected:

Alternative	Reason Rejected
Server-side tagging / proxy routing	Retains identity-behavior join capability at operator level; Austrian DSB found this insufficient (2022); German SDM unlinkability not satisfied
Pseudonymization with lookup table	Join key exists in lookup table; operator could derive association; Austrian DSB standard not met
EU data residency only	Addresses Schrems II transfer mechanics but not representability risk; identity-behavior join remains in canonical state
Aggregate-only analytics (Plausible / Fathom / Cloudflare)	Does not support user-authenticated retrieval, credential-free erasure, or period-close compliance attestation; insufficient for enterprise requirements

Proportionality Assessment

Processing is proportionate. The controller’s legitimate interests (product improvement, service quality, regulatory audit compliance) are balanced against data subject privacy interests. Data subject impact is reduced at the canonical state layer: the canonical state contains no identity-behavior join, so canonical-layer profiling, behavioral surveillance, and re-identification are structurally constrained rather than managed only through organizational controls. Period-close HSM attestation provides regulatory verifiability without individual exposure from canonical state.

RISK ASSESSMENT AND MANAGEMENT

Risk Assessment and Management

Threats

#	Threat	Materialisation	Risk Source	Impact on Data Subjects
1	Canonical state breach	Attacker extracts full ledger state	Infrastructure vulnerability	Session identifiers and sealed payloads exposed; identity hashes exposed; no join derivable from canonical state alone
2	Off-chain reconciling store breach	Database compromise	Infrastructure vulnerability	Per-user behavioral history exposed for affected authenticated users
3	Sealer key compromise	Sealer key stolen or leaked	Key management failure; internal threat	Sealed behavioral payloads decryptable; identity-behavior join still not available without canonical join key
4	IDV provider breach	IDV credential database or signing key compromised	Third-party risk	Identity re-derivation risk; behavioral history not exposed without separate reconciling store breach
5	Reconciling API authentication bypass	Auth layer circumvented	Implementation vulnerability	Per-user history exposed without user participation

#	Threat	Materialisation	Risk Source	Impact on Data Subjects
6	SDK supply chain compromise	Malicious or tampered SDK version distributed	Supply chain attack	Rejection predicate bypassed; canonical join written; structural guarantee broken

Method Likelihood scale: 1 (Negligible) — 2 (Limited) — 3 (Significant) — 4 (Maximum)

Severity scale: 1 (Negligible) — 2 (Limited) — 3 (Significant) — 4 (Maximum)

Risk level: Likelihood $\times$ Severity. Acceptable residual threshold: ≤ 4 . Risks scoring 5–6 inherently require mitigating measures before proceeding.

Modulating factors: structural non-representability of canonical state is a downward-modulating factor for all threats involving canonical ledger breach.

Patent-alignment note: this DPIA is the assessment vehicle for the Mainhub patent posture. The write-side guarantee is canonical-state non-representability: accepted canonical state contains no identity–payload join, no shared observable, and no validator-accepted execution path that computes the participant-specific association from canonical state alone. The reconcile-side control is separate: any recovery, reveal, deletion, restore, redeem, or presence-check workflow must use protected linkage, non-enumerable single-subject retrieval, and provider/authority partitioning. This combined posture does not eliminate risk in the full system. Protected linkage stores, reconciling interfaces, IDV or wallet providers, endpoint/browser state, network timing, controller configuration, and compelled disclosure remain DPIA risk surfaces.

Provider Partition Assessment

Role / provider	Permitted visibility
IDV or authentication provider	Real-world identity, biometric/session evidence, and identity commitment
Protected linkage store provider	Identity commitment to submission identifier or recovery reference for
Reconciling authority	Fresh authenticated request, one permitted action, and at most one
Canonical commit authority / validators	Canonical List 1 and List 2 records, aggregate evidence, and state-tr
Telemetry / support provider	Operational metrics and support artifacts necessary to run the servi

DPIA Audit Findings This DPIA is the audit record for the browser analytics processing pattern. The scored risk tables below assess the canonical-state guarantee, protected-linkage and reconcile tier, provider partitioning, endpoint/browser exposure, network correlation, IDV

or wallet provider risk, and controller-configuration risk. No separate patent-alignment audit is relied on for this processing decision.

Authority Partition This is a sealer-governed embodiment (no unique-person count-match). Three parties:

Authority	Role
Auth (Cognito)	Account layer; always required; authentication gate for erasure requests — does NOT h
IDV/KYC (Didit)	Verifies account belongs to a real, verified person; assessed on authenticated users
Reconciling authority	Off-chain linkage store + sealer keys

Because this is a sealer-governed deployment, no eligibility authority key is registered and the rescission mechanism is structurally unavailable. The worst-case unilateral threat is payload disclosure via the sealer (reconciling authority).

Inherent Risk Assessment

Risk	Likelihood	Severity	Modulating Factors	Risk Level	Acceptable?
Canonical state breach	2	2	Structural: no join in canonical state limits harm materially even on full breach	4	Yes (inherent)
Off-chain store breach	2	3	Identity-gated access limits exposure to individually authenticated users only	6	Requires mitigation
Sealer key compromise	1	3	HSM-backed; key rotation; join still unavailable	3	Yes

Risk	Likelihood	Severity	Modulating Factors	Risk Level	Acceptable?
IDV provider breach	2	2	Third-party controls; behavioral history not held by IDV	4	Yes
Reconciling API auth bypass	1	3	IDV re-auth per request; no session persistence	3	Yes
SDK supply chain compromise	1	4	Signed releases; open-source audit; patent-documented rejection predicate as reference	4	Yes

Action Plan

Additional Mitigating Measures

#	Measure	Mitigated Risk	Effectiveness	Status
1	Encryption at rest — CockroachDB EU-region	Off-chain store breach	Standard; reduces severity from 3 to 2	Implemented
2	Annual independent security audit of SDK rejection predicate	Supply chain / implementation	High — predicate is the core structural guarantee	Planned (pre-launch)
3	IDV re-authentication on every reconciling request (no session persistence)	Reconciling API auth bypass	High — eliminates session hijack vector	Implemented

#	Measure	Mitigated Risk	Effectiveness	Status
4	Sealer key rotation policy (quarterly) with HSM custody	Sealer key compromise	Standard; limits exposure window	Planned (pre-launch)
5	Signed SDK releases with reproducible build verification	Supply chain	High — detectable tampering	Planned (pre-launch)
6	Protected-linkage controls: provider partitioning between linkage store, IDV/auth provider, and reconciling authority where supported; tenant scoping; least-privilege operator access; reconcile audit logs; retention limits; and dual-control review for non-user-initiated reconcile	Off-chain linkage and lawful process misuse	High — prevents any ordinary single provider from reconstructing the full identity-payload association and aligns the operational tier with the patent’s protected linkage store constraint	Planned (pre-launch)
7	Browser/endpoint controls: session sealing, ingress shuffling, write-only fallback, one-tap local wipe, and explicit no-global-adversary claim boundary	Endpoint, local, and network correlation	Medium/High — reduces correlation risk but does not replace Tor/VPN/opsec for high-threat users	Partially implemented; deployment-dependent

#	Measure	Mitigated Risk	Effectiveness	Status
8	Domain-gating review before reuse outside browser analytics: customer DPIA trigger, legal-basis check, identity-mode selection, and controller configuration sign-off	Overextension of browser analytics DPIA to voting, health, finance, workplace, betting, real estate, or camera/IoT domains	High — prevents relying on the browser analytics DPIA for materially different patent embodiments	Planned

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** ([patent/mainhub/dpia/source/COM](https://shyware.fyi/legal) published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production.
- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that `eligibility_authority_key` $\neq$ `reconciling_authority_key` $\neq$ `auth_key`.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment

Risk	Additional Measures Applied	Residual Likelihood	Residual Severity	Residual Level	Acceptable?
Canonical state breach	— (structural mitigation inherent)	2	1	2	Yes
Off-chain store breach	Encryption at rest (#1)	2	2	4	Yes
Sealer key compromise	Key rotation (#4)	1	2	2	Yes
IDV provider breach	—	2	2	4	Yes
Reconciling API auth bypass	IDV re-auth per request (#3)	1	2	2	Yes
SDK supply chain	Signed releases + audit (#2, #5)	1	3	3	Yes, conditional on pre-launch completion
Protected linkage store compulsion or misuse	Protected-linkage controls (#6), including provider partitioning where enabled	1	3	3	Yes, for browser analytics where no single ordinary provider holds both identity authority and linkage authority; domain DPIA required for voting, health, finance, or legal-process-heavy deployments

Risk	Additional Measures Applied	Residual Likelihood	Residual Severity	Residual Level	Acceptable?
Endpoint/browser or network correlation	Browser/endpoint controls (#7)	2	2	4	Yes for moderate-risk users; not acceptable for hostile-state or coercion-sensitive deployments without separate transport/opsec controls
Controller configuration or domain extension beyond reference scope	Domain-gating review (#8)	2	2	4	Yes only if gated before production reuse

All residual risks are at or below the acceptable threshold of 4 only under the browser-analytics reference scope and only after planned pre-launch controls are completed. The patent's canonical-state structural guarantee supports reduction of canonical-state breach risk; it does not by itself make protected linkage, endpoint, network, IDV/wallet, or controller configuration risks negligible. The software evidence for the core kernel may be complete while those deployment controls still need to be fixed for this domain.

Plan

Activity	Responsible	Timeline
Execute Article 28 DPA with cloud infrastructure provider	Legal / Procurement	Pre-launch
Complete IDV provider Chapter V transfer assessment and SCCs	Privacy Counsel	Pre-launch

Activity	Responsible	Timeline
Implement sealer key rotation policy (quarterly, HSM custody)	Product Engineering	Pre-launch
Implement signed SDK release pipeline with reproducible builds	Product Engineering	Pre-launch
Engage external auditor for SDK rejection predicate audit	Product Engineering + DPO	Within 6 months of launch; annually thereafter
Off-chain store penetration test	Security Team	Pre-launch; annually thereafter
Trigger DPA prior consultation if residual risk reassessed above threshold	DPO + Legal	As triggered

INVOLVEMENT OF INTERESTED PARTIES

DPO Advice

DPO review pending.

DPO opinion, conclusions, and recommendations: pending DPO review.

Implementation of DPO advice: pending DPO review.

Views of Data Subjects or Their Representatives

Data subjects were not directly consulted. Rationale: the processing does not involve vulnerable data subjects; the primary privacy risk (canonical-layer operator profiling from ledger state) is structurally reduced by architecture rather than managed through organizational controls alone. Protected linkage, endpoint/browser, network, IDV/wallet, and controller-configuration risks remain operational risk surfaces; user-authenticated retrieval and credential-free erasure are supported without requiring data subject input at DPIA stage.

Consultation should be considered if processing is extended to vulnerable groups (minors, employees, public sector data subjects) or if processing scope materially changes.

CONCLUSION AND DECISION

Decision: CONDITIONALLY APPROVED — processing may proceed after all conditions below are met.

Condition	Description
1	Article 28 DPA executed with cloud infrastructure provider
2	IDV provider Chapter V transfer assessment completed; SCCs executed where applicable
3	Sealer key rotation policy implemented with HSM custody pre-launch
4	Signed SDK release pipeline operational pre-launch
5	External audit of SDK rejection predicate engaged; first audit within 6 months of launch
6	Protected-linkage controls and provider partitioning implemented before any hosted reconcile or recovery workflow is offered
7	Browser/endpoint correlation controls documented, including the boundary that shybrowser is not a global-adversary transport guarantee
8	Domain-gating review completed before using this browser analytics DPIA as support for any non-browser analytics deployment

Justification: For the browser-analytics reference scope, and conditional on the listed pre-launch controls, residual risks are at or below the acceptable threshold of 4. The Shyware architecture supports: (i) the Austrian DSB re-identification standard for the canonical layer — canonical state does not contain the identity-behavior join; (ii) the German SDM unlinkability protection goal for canonical state — structural unlinkability is enforced by the write-side state machine, not by policy alone; and (iii) Article 25 GDPR design support at the canonical state-machine layer. This conclusion does not extend the patent’s canonical-state guarantee to the protected linkage store, reconciling interface, endpoint/browser state, IDV or wallet provider, network transport, or controller configuration. No DPA prior consultation is required under Article 36 GDPR for the reference browser-analytics deployment while residual risks remain below the threshold. See Annex A for deployment-specific requirements; Annex B for ePrivacy consent obligations; Annex C for jurisdiction-specific enforcement posture; and Annex D for the Art. 9 inference risk assessment framework.

Regulatory and Deployment Context Annexes

Annex A — Deployment Context Variants

The baseline DPIA conclusion applies to general-purpose behavioural analytics (e-commerce, SaaS, media). The following contexts require additional controls before the conclusion holds.

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
Health or medical website	Behavioural patterns reveal health conditions or medication use even without explicit health data in payload — Art. 9(1) inferred special category	Art. 9(1) GDPR; HIPAA §164.514(b) (US)	Explicit Art. 9(2)(a) consent per session; DPO consultation; separate Art. 9 DPIA section; HIPAA BAA if US PHI involved
Political or civic content	Browsing patterns reveal political opinions or voting behaviour — Art. 9(1) inferred special category	Art. 9(1) GDPR; election data laws per jurisdiction	Explicit Art. 9(2)(a) consent; do not combine with voter-roll data; controller legal-basis review
Workplace monitoring	Behaviour data = employee surveillance; Art. 6(1)(f) insufficient under many member-state laws	German BDSG §26; CJEU <i>López Ribalda</i> ; UK ICO Employment Guidance	Works council consultation (DE/FR/AT/NL); explicit notice before monitoring; proportionality review; legitimate interest balancing test documented
Financial services	Transaction-page behaviour can reveal financial health, credit-seeking behaviour (sensitive inferential risk)	EU AMLD6; CCPA 1798.140(v) “sensitive” data if financial	Legal basis review; Art. 13 notice update; consider consent where LIA insufficient
Children’s services	Behavioural profiling of minors prohibited or consent-constrained	Art. 8 GDPR; COPPA (US, under 13); AADC (UK)	Age-verification gate before analytics activation; no behavioural profiling without parental consent

Annex B — ePrivacy and Cookie Consent Requirements

The shybrowser canonical-state architecture does not substitute for ePrivacy Directive Art. 5(3) consent obligations. The structural non-linkability property operates at the canonical ledger layer; the network request and session-initiation layer remain subject to cookie/tracker consent rules.

- **EU / EEA:** ePrivacy Directive Art. 5(3) requires prior informed consent before storing or accessing information on a user’s terminal equipment. Structural non-linkability does not exempt the operator from this consent requirement for the initial tracking event. CNIL, DSK, and Datatilsynet have each found that Google Analytics transfers personal data to the US in violation of GDPR even where IP anonymisation is configured; shybrowser’s EU-only infrastructure removes the transfer risk but consent for the tracking event itself remains required.
- **UK:** PECR Reg. 6 (same consent requirement). UK ICO enforcement is active on analytics tracking.
- **US (California):** CCPA/CPRA “sharing” for cross-context behavioural advertising requires opt-out right even where no sale occurs. If shybrowser is deployed as part of an advertising context, a “Do Not Sell or Share” mechanism is required regardless of canonical-state non-linkability.
- **Consent exemption:** Member states permit analytics cookies/trackers without consent where: (a) the data is not used for any purpose other than audience measurement; (b) the data is not transferred or shared; and (c) the data does not leave the operator’s control. shybrowser’s structural non-linkability and operator-only reconcile interface support this exemption analysis, but the operator must document reliance on the exemption and confirm it applies in each deployment jurisdiction.

Annex C — Jurisdiction-Specific Enforcement Posture

Jurisdiction	Enforcement context	Shyware structural property	Remaining operator obligation
France (CNIL)	CNIL ordered cessation of Google Analytics (Jan 2022, Mar 2022); grounds: US data transfer without adequate safeguards; IP anonymisation insufficient	shybrowser with EU-only infrastructure eliminates the transfer risk CNIL identified; no sessionId–identity–activity join in canonical state	ePrivacy consent for tracking event; privacy notice disclosure; DPA with EU processor

Jurisdiction	Enforcement context	Shyware structural property	Remaining operator obligation
Austria (DSB)	DSB: Google Analytics unlawful (Jan 2022); confirmed canonical-state transfer as the violation	Same as France	Same as France
Norway (Datatilsynet)	Final decision Jan 2025; same grounds as France/Austria	Same as France	Same as France
Germany (DSK)	DSK guidance: analytics tools that transfer data to US are presumptively unlawful; Matomo self-hosted with anonymisation acceptable	shybrowser’s structural non-linkability exceeds Matomo’s anonymisation — no individual-level record in canonical state at all	Works council consultation for workplace deployments; BDSG §26 for employee data
Ireland (DPC)	LinkedIn €310M fine Oct 2024 (behavioural advertising without consent); Meta €1.2B fine May 2023	Structural non-linkability addresses the identity–behaviour join cited in DPC enforcement; does not substitute for consent where required	Consent or LIA balancing test documented; Art. 13 notice; DPO registration if large-scale systematic processing
US (California)	CCPA/CPRA; AG enforcement on “sharing” for advertising	No US-specific federal analytics law; CCPA applies to California residents	Opt-out right for sharing; privacy notice; data broker registration if applicable

Annex D — Art. 9 Inference Risk Assessment

Art. 9 may apply to behavioural analytics deployments even where no explicit special-category data is collected, if the combination of behavioural signals permits inference of a special-category attribute. The following assessment framework applies:

1. **Content type check.** Does the operator’s website or application serve content primarily about: health/medicine, mental health, reproductive health, political news/campaigns, religion/beliefs, trade union activities, sexual orientation/gender identity, race/ethnicity, or criminal history? If yes, proceed to step 2.
2. **Inference feasibility check.** Can the sealed behavioural payload (page visits, search terms, interaction patterns) be combined with any other operator-held data to yield a

special-category inference at the individual level? Even where canonical state prevents the join, operator-side context data may permit inference.

3. **Outcome.** If both checks are positive: the deployment is Art. 9 processing; the operator must identify an Art. 9(2) basis (typically explicit consent); a supplementary Art. 9 DPIA section is required; this DPIA's baseline conclusion does not apply without that supplement.